

CVE Report — Dependency Scan

Project: **vulnerable-invoice-service** · Stage 1 — Dependency Scanner (OWASP Dependency-Check + Maven) · Commit `61ed8c3` · Generated 2026-07-04

Summary

Metric	Count
Dependencies scanned (resolved)	23
Dependencies unresolved (flagged)	1
Total dependency coordinates	24
CRITICAL CVE findings	16
HIGH CVE findings	46
MEDIUM CVE findings	12
LOW CVE findings	1
Outdated dependencies	8
License violations	1
Supply-chain alerts	1

CRITICAL — Typosquatted dependency. `com.fastxml.jackson.core:jackson-databind:2.9.8` (note the missing "er" in `fastxml`) impersonates the legitimate `com.fasterxml.jackson.core:jackson-databind` coordinate declared elsewhere in the same `pom.xml`. It does not exist on Maven Central and fails to resolve — treated here as a supply-chain risk finding rather than a silent build failure.

CRITICAL — Log4Shell present. `org.apache.logging.log4j:log4j-core:2.14.1` carries **CVE-2021-44228** (CVSS 10.0), the Log4Shell remote-code-execution vulnerability, and is actively imported by `DiscountCalculator.java`. Upgrade to `2.25.4` to clear every CVE found on this branch.

HIGH — Copyleft license violation. `mysql:mysql-connector-java:8.0.30` is licensed `GPL-2.0` with FOSS exception, a copyleft license pulled into an otherwise permissive (Apache-2.0 / BSD / MIT) dependency set.

Vulnerable dependencies

Coordinate	Scope	CVEs	Max severity	Top CVE (CVSS)	Fix version
<code>org.apache.logging.log4j:log4j-core:2.14.1</code>	compile (direct)	8	CRITICAL	CVE-2021-44228 (10.0)	2.25.4

com.fasterxml.jackson.core:jackson-databind:2.9.8	compile (direct)	54	CRITICAL	CVE-2019-14379 (9.8)	2.16.0
com.google.protobuf:protobuf-java:3.19.4	compile (transitive, via mysql-connector-java)	4	HIGH	CVE-2024-7254 (7.5)	3.25.5
mysql:mysql-connector-java:8.0.30	compile (direct)	1	HIGH	CVE-2023-22102 (8.3)	8.1.0
org.apache.logging.log4j:log4j-api:2.14.1	compile (direct)	2	HIGH	CVE-2026-34479 (7.5)	2.25.4
com.google.guava:guava:24.1.1-jre	compile (direct)	2	HIGH	CVE-2023-2976 (7.1)	32.0.0
com.fasterxml.jackson.core:jackson-annotations:2.9.0	compile (transitive, via jackson-databind)	1	MEDIUM	CVE-2018-1000873 (6.5)	2.9.8
org.apache.commons:commons-lang3:3.4	compile (direct)	1	MEDIUM	CVE-2025-48924 (5.3)	3.18.0
commons-io:commons-io:2.4	compile (direct)	2	MEDIUM	CVE-2021-29425 (4.8)	2.14.0
com.fastxml.jackson.core:jackson-databind:2.9.8	compile (direct, unresolvable)	n/a	CRITICAL (typosquat)	—	remove coordinate

jackson-databind's full 54-CVE list (24 CRITICAL, 24 HIGH, 6 MEDIUM) is preserved verbatim in `depscan-report.json` and the raw `dependency-check-report.json`; this table shows the top finding per dependency for readability.

Outdated dependencies

Coordinate	Current	Latest	Update type
org.junit.jupiter:junit-jupiter	5.10.2	6.1.1	major
org.apache.logging.log4j:log4j-core	2.14.1	3.0.0-beta3	major
org.apache.logging.log4j:log4j-api	2.14.1	3.0.0-beta2	major
com.google.guava:guava	24.1.1-jre	33.6.0-jre	major
com.fasterxml.jackson.core:jackson-databind	2.9.8	2.22.0	minor
org.apache.commons:commons-lang3	3.4	3.20.0	minor
commons-io:commons-io	2.4	2.22.0	minor
mysql:mysql-connector-java	8.0.30	8.0.33	patch

License findings

Coordinate	License	Status
mysql:mysql-connector-java:8.0.30	GPL-2.0 with FOSS exception	VIOLATION
All other resolved dependencies (22)	Apache-2.0 / BSD-3-Clause / EPL-2.0	OK

Supply-chain flags

Coordinate	Flag	Detail
------------	------	--------

`com.fastxml.jackson.core:jackson-databind:2.9.8`

TYPOSQUAT_SUSPECTED

Unresolvable coordinate impersonating
`com.fasterxml.jackson.core:jackson-databind`.

Methodology

- **Tree resolution:** `mvn dependency:tree` (all scopes) against a scratch copy of `pom.xml` with the unresolvable typosquat entry removed for tooling purposes only — the repository's real `pom.xml` was **not** modified. 23 of 24 declared coordinates resolved; the typosquat entry is reported as a standalone supply-chain finding above.
- **Vulnerability scan:** `mvn org.owasp:dependency-check-maven:check` (engine 12.2.2), JSON output, reusing the warm NVD cache under `~/.m2/repository/org/owasp/dependency-check-data` (`-DautoUpdate=false`). Every returned CVE already carried a scanner `cvssv3.baseScore`, so **no** NVD fallback queries were needed (`cvss_source: "scanner"` for all findings).
- **Outdated scan:** `mvn versions:display-dependency-updates -DprocessDependencyManagement=true`.
- **License scan:** `mvn org.codehaus.mojo:license-maven-plugin:aggregate-third-party-report`.

Full machine-readable output: `depscan-report.json` (repo root). Handed to the **Risk Scoring Agent** (Stage 2) for prioritization — see `Risk-Scoring-Report.md`.